Monthly Intelligence Dispatch

February 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- According to Russian National Computer Incident Response & Coordination Center Russian medical organizations have fallen victims to ransomware attacks in 2020. Experts at Group-IB attributed some of the attacks to OldGremlin hacker group.
- In Oldsmar, Fla., unidentified cybercriminals infiltrated the computer systems that operate a water treatment. As a result, the attackers could remotely control the chemical composition of water.
- The anti-malware solutions provider Emsisoft disclosed a data breach. The company revealed that an unidentified third-party had accessed a publicly exposed database.
- Researchers at Malwarebytes corporation discovered that MageCart JS sniffer not only infects online shops and steals bank card data of the customers but also exploits other hackers' malware.
- The FonixCrypter operators deleted the source code of their ransomware and announced that they are planning to cease their activity.
- Kia Motors America, a subsidiary of the largest automobile manufacturer suffered a suspected DoppelPaymer ransomware attack.
- Ukrainian police arrested a 39-year-old man on accusations of developing and advertising one of the most advanced and widely used phishing toolkits of the underground hacking scene. The suspect was arrested following an international investigation between law enforcement agencies in Australia, the US, and Ukraine. According to Zdnet, the phishing instrument is called uPanel (also known as U-Admin).

OldGremlin

According to Russian National Computer Incident Response & Coordination Center (NCIRCC) Russian medical organizations have fallen victims to ransomware attacks in 2020. “It is the first case of a ransomware attack against medical organizations in Russia,” said Nikolay Murashov, the deputy head of NCIRCC. One of the incidents was covered by Group-IB in the last year’s report on OldGremlin, a Russian-speaking ransomware group, that defied the unspoken rule about hacking on home soil. In August 2020, a large medical company with a network of regional branches fell victim to OldGremlin. The attack began with a phishing letter allegedly written on behalf of RBC media holding employee. A few weeks later the attackers deleted the organization's data backups to make it impossible for the organization to recover the information. On the weekend the attackers used the same server to distribute their TinyCryptor ransomware to hundreds of computers in the corporate network in just a few hours. As a result, the attack paralyzed the work of the company’s regional divisions. The attackers demanded a ransom of $50,000 in cryptocurrency for decrypting the data. A little earlier, in spring, OldGremlin sent out letters with the subject “Free Covid-19 vaccine” allegedly on behalf of "Apteka.ru“. The email contained a presentation with "the best means of prevention at an affordable price." as well as ransomware. The attack targeted 70 recipients including Russian oil and gas companies.

CII

In Oldsmar, Fla., unidentified cybercriminals infiltrated the computer systems that operate a water treatment. As a result, the attackers could remotely control the chemical composition of water. In particular, the attackers increased the amount of sodium hydroxide used to regulate the acidity level of water. This element, however, can be dangerous for people if water contains elevated level of it. Fortunately, none of the residents of Oldsmar were harmed by the cybercriminals. The Pinellas county authorities are currently investigating the incident, they are to understand how the hackers managed to infiltrate the city's infrastructure. The FBI agents also got involved in the case and notified the nearby communities of the possible danger. This is not the first time that critical infrastructure has been attacked. In the spring of 2020, the Israeli National Cyber Directorate (INCD) warned the companies operating in the energy and water supply sector of possible cyberattacks on automated process control systems (APCS) of water treatment plants, pumping stations and sewer networks. The security alert of the agency urged companies to change passwords for all internet-connected systems. Later, the New York Times, referred to its sources, saying that the hackers did manage to gain access to water treatment systems and even tried to remotely change the level of sodium hydroxide which could cause poisonings in the area.

Group-IB's digital forensics specialists say that the entry point for 90% of the attacks against technological segment is the corporate network according to the first two scenarios. Therefore, solutions that ensure infrastructure security of industrial and production facilities must be comprehensive and capable of detecting cyberattacks at any stage. Their objective is to provide a comprehensive control of the network, monitor anomalies and non-standard network activity of the APCS, register the undocumented capabilities of industrial protocols, and track all activities in the network.

Emsisoft

The anti-malware solutions provider Emsisoft, revealed that a third-party had accessed a publicly exposed database containing technical logs. The root cause of the incident was a misconfiguration of a database used in a test environment that got exposed to the Internet. The system was used to evaluate and benchmark possible solutions for the storage and the management of the log data generated by Emsisoft products and services. The leak was caused by one of the company's employees. There was little confidential information in the database, only 14 email addresses belonging to seven different organizations. The database, however, stored many production logs. Investigation revealed that at least one person "had access to some or all the data in this database." The 14 email addresses stored in the database got there through the scanner logs, as the system detected malicious emails in users' email clients.

StormShield

French cybersecurity company StormShield, a major provider to the French government revealed that it had suffered a security breach. An unidentified hacker stole customers’ personal and technical data after gaining access to the corporate portal. Stormshield also discovered that some of the source code for the Stormshield Network Security (SNS) firewall used in French government networks was also stolen. Investigation backed up by the French National Agency for Security of Information Systems (ANSSI) is in progress. The ANSSI experts are now assessing the possible impact of the hacking on government systems.

JS sniffer

Researchers at Malwarebytes corporation discovered that MageCart script (a JS sniffer according to Group-IB's classification) not only infects online shops and steals bank card data of the customers but also exploits other hackers' malware. Initially, the name MageCart was attributed to a hacker group, which was the first to inject web skimmers (malicious JavaScript) onto online store pages to steal bank card data. This approach was so successful that the group soon had numerous imitators, and the name MageCart became a generic name, and now it denotes a whole class of such attacks. Researchers discovered a new skimmer while investigating a wave of hacks in online stores running under the outdated Magento 1. Costway company, which used Magento 1 for its online stores in France, the UK, Germany and Spain, fell victim to these attacks. That is, the first hacker group compromised the company's websites and injected fake payment forms that stole the financial data of customers. The second hacker group additionally uploaded their own custom web skimmers to these sites from the securityxx[.]top domain. This way, one script collects data from an existing skimmer of the first group, and the second is activated only if the store was cleared of malware injected during the initial Magento 1 hack.

According to Viktor Okorokov, Group-IB Threat Intelligence specialist, JS sniffers are one of the fastest developing threats to the e-commerce market in the world. "In less than a year and a half since the release of the first Group-IB research on this topic, the number of unique families of such malicious code discovered by Group-IB experts has more than doubled: today there are 96 of them." Viktor Okorokov says that JS sniffers have finally ousted banking Trojans. "Since the end of 2019 criminal groups using such malware have become the main suppliers of text databases that contain bank card data for sale in card shops, specialized hacker forums."

Google Apps Script

The attackers use Google Apps Script, a scripting platform designed for application development to steal bank card data. This hacker campaign targeted customers of online shops. Attackers used script.google.com domain to hide their activities from malware scanners and bypass Content Security Policy. Cybercriminals relied on this domain because online stores trust it. Marketplaces mark all Google subdomains as trusted ones by default. Using this cover the attackers deploy a web skimmer that extracts customers' billing information. Typically, it is a JavaScript injected directly on the store's web pages. Once attackers embed such a script in the store, they can intercept data entered by users, including payment and personal information. The extracted data is then transferred to the attacker’s server. This scheme caught the attention of malware analyst Eric Brandel, who said that first the stolen data was transferred to Google Apps Script application via script[.]google[.]com domain used as an endpoint. Then the information was redirected to analit[.]tech, another server controlled by the attackers and located in Israel.

.

DoppelPaymer

Kia Motors America, a subsidiary of the largest automobile manufacturer suffered a suspected DoppelPaymer ransomware attack. The attackers infiltrated the system, encrypted important data and now demand 404 bitcoins worth about $20 million in exchange for a decryptor. The attackers threaten to publish the exfiltrated data if Kia Motors America fails to provide the ransom within 2-3 weeks. The ransomware group created a special website where they publish exfiltrated corporate information of the victims. If the company fails to negotiate the ransom would increase to 600 Bitcoins worth about $30 million.

FonixCrypter

The FonixCrypter operators deleted the source code of their ransomware and announced that they are planning to cease their activity. They also released a decryption tool and the master decryption key, along with instructions to recover the files. The availability of the master decryption key allows the victims to recover their encrypted files for free. FonixCrypter Ransomware has been active since 2020 and received regular updated. At least seven different versions of FonixCrypter were released last year. Security researchers for threat intelligence firm Recorded Future, have already tested the decryptor and verified that the FonixCrypter app, instructions, and master key work as advertised.

CD Projekt Red

CD Projekt Red game studio disclosed ransomware attack. The attackers claimed they obtained copies of the source code for games like Cyberpunk 2077, Gwent, and The Witcher 3, along with an unreleased version of The Witcher 3 game, and documents relating to accounting, administration legal and HR. The game studio said that it will not give in to the demands or negotiate with threat actor because there is still possibility that compromised data can be disclosed later. According to Emsisoft security researcher, judging by the shared ransom note, the attacker behind the CD Projekt Red attack has been identified as a ransomware gang going by the name of HelloKitty. The ransomware has been active since November 2020 targeting large companies, such as CEMIG, a Brazilian power company, which fell victim to the ransomware in the past.

Hunter	CERT-GIB experts identified the type of malware the hackers used to hijack the account from Nikita Mogutin, co-founder of the popular Telegram channel Baza (320,000 subscribers). The attackers used the Hunter stealer, which was sent to Nikita Mogutin under the guise of an educational platform advertisement. The stealer targets Windows devices, which is why the attackers kept asking the journalist to open the archive on his work computer, and not from his iPhone. Fortunately, he did not succumb to their persuasion. Hunter stealer automatically collects accounts on an infected computer, then sends them to an attacker. Previously, this stealer was often used to steal credentials from GTA players or cryptocurrency.
LodaRAT	LodaRAT malware was known to target Windows devices, but now it switched to users of mobile devices. As part of the new campaign the attackers target Android cellphones. The main task of LodaRAT is to spy on the victims and steal their data. LodaRAT was first spotted in 2016. Since then, the operators of this malware released many versions of this program written in AutoIT programming language.

Arrests and sentences

Egregor

In February members of the Egregor ransomware cartel have been arrested in Ukraine as a result of a joint investigation between Ukrainian and French law enforcement agencies. The names and number of the suspects have not been released yet. According to France Inter, the suspects provided hacking, logistical, and financial support for the Egregor group. French authorities got involved in the investigation after several major French companies including Ubisoft game studio and logistics firm Gefco were hit by Egregor. The Egregor gang, has been active since September 2020, it operates based on a Ransomware-as-a-Service (RaaS) model.

uPanel

Ukrainian police arrested a 39-year-old man on accusations of developing and advertising one of the most advanced and widely used phishing toolkits of the underground hacking scene. The suspect was arrested following an international investigation between law enforcement agencies in Australia, the US, and Ukraine. According to Zdnet, the phishing instrument is called uPanel (also known as U-Admin). U-Admin is a control panel for receiving logs from phishing kits and managing interaction with the victim. U-Admin is also used for injections of code snippets into the victim's browser, which allows the attacker to collect more information. U-Admin is not sold separately, but it is included in the price if you buy one of [the author's] phishing pages/injections. Phishing attacks launched by uPanel targeted financial institutions in Australia, Spain, the United States, Italy, Chile, the Netherlands, Mexico, France, Switzerland, Germany, and the United Kingdom. For example, 50% of all phishing attacks targeting Australian users in 2019 were carried out using uPanel. According to investigators, the suspect not only wrote a phishing kit and advertised it, but also provided technical support to his customers.

Forecasts and warnings

- Ransomware, which blocks access to data and demands ransom to recover valuable information, will continue to be the number one threat. What is more, cybercriminals changed their tactics and now they not only block information, but also threaten to disclose it if the victim organization refuses to pay the ransom.
- The motives of cybercriminals attacking APCS can be different, for example equipment sabotage, production shutdown or military reconnaissance. In most cases attackers use three main scenarios. 1) Targeted attacks which usually involve mailing out malware to work computers in the corporate network using social engineering. Sometimes targeted attacks on industrial networks take years to develop. 2) Using external perimeter as an entry point. Attackers penetrate the corporate network through external web services such as corporate portal or mail service. 3) Attacks on enterprises using the air gap approach, i.e., search for an "air gap" to physically penetrate isolated critical network segments. In this case, malware can be deployed in the industrial network, for example, via flash drives.
- To reduce the risk of personal data leaks, Group-IB DRP experts recommend sticking to the rules of digital hygiene: use only strong passwords for your accounts and change them regularly, configure additional security measures such as two-factor authentication, and login only from trusted sources, etc. Do not use unofficial programs and applications.
- Classified platforms are full of offers to sell Clubhouse invitations for Clubhouse $20, besides resellers there may be scammers hiding behind classified ads. In addition, suspicious Clubhouse clones have been spotted in Android PlayMarket though the social network only works on iOS so far. It is possible that in the future, the attackers will try to record voice and use it for phone calls or create DeepFake.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com